

Microsoft Entra ID

General Theory Notes

Complete theory – Architecture, Identity Models, Users, Groups, MFA, Conditional Access, PIM, Identity Protection, Enterprise Apps, B2B, Governance, Monitoring

1. What is Microsoft Entra ID?
2. Entra ID vs On-Premises Active Directory
3. Identity Models – Cloud, Hybrid, Federated
4. Entra ID Object Types
5. User Management and Lifecycle
6. Group Types and Management
7. Authentication Methods and MFA
8. Self-Service Password Reset (SSPR)
9. Conditional Access – Complete Theory
10. Privileged Identity Management (PIM)
11. Identity Protection and Risk Policies
12. Enterprise Applications and SSO
13. App Registrations and Service Principals
14. B2B External Collaboration
15. Entra Connect – Hybrid Identity
16. Access Reviews and Governance
17. Monitoring – Logs, Workbooks, Diagnostics
18. Key Concepts and Definitions

Section 1 – What is Microsoft Entra ID?

1.1 Definition

Microsoft Entra ID (renamed from Azure Active Directory in 2023) is Microsoft's cloud-based identity and access management (IAM) service. It is the backbone of authentication and authorisation for Microsoft 365, Azure, and thousands of third-party SaaS applications. Every Microsoft 365 tenant automatically gets a Microsoft Entra ID instance.

Entra ID is NOT the same as on-premises Active Directory. It uses completely different protocols, runs in the cloud, and manages cloud identities. Think of it as "Active Directory for the cloud" but rebuilt from the ground up with modern security in mind.

1.2 What Entra ID Manages

- Users: cloud identities, guest accounts, synced users from on-premises AD
- Groups: security groups, M365 groups, dynamic groups, mail-enabled security
- Devices: Entra joined, hybrid joined, registered devices managed by Intune
- Applications: enterprise apps (SSO), app registrations (custom apps), service principals
- Authentication: MFA, passwordless, SSPR, Conditional Access policies
- Governance: PIM, access reviews, entitlement management, lifecycle workflows

1.3 Entra ID Licensing Tiers

Tier	Included With	Key Features
Free	Any Microsoft 365 plan	Basic users and groups, SSO for 10 apps, basic MFA via Security Defaults

Tier	Included With	Key Features
Entra ID P1	Microsoft 365 Business Premium, E3	Conditional Access, Dynamic Groups, SSPR, hybrid identity, group-based licensing
Entra ID P2	Microsoft 365 E5 or standalone	All P1 plus PIM, Identity Protection, Access Reviews, risk-based CA

* Your Lab: Business Premium includes P1. You activated a 30-day P2 free trial to use PIM and Identity Protection. Always check which tier a feature requires before promising it to a customer.

Section 2 – Entra ID vs On-Premises Active Directory

2.1 Key Differences

Aspect	On-Premises AD (AD DS)	Microsoft Entra ID
Where it runs	Windows Server in your datacenter	Microsoft cloud datacenters globally
Protocols	Kerberos, NTLM (legacy)	OAuth 2.0, OpenID Connect, SAML 2.0 (modern)
Joined devices	Domain Join via Kerberos	Entra Join, Hybrid Join, or Entra Registration
Primary objects	Users, Groups, Computers, OUs, GPOs	Users, Groups, Devices, Applications, Service Principals
Management tools	ADUC, GPMC, DNS, ADSS consoles	entra.microsoft.com, PowerShell (Microsoft Graph)
MFA support	Requires NPS extension or ADFS	MFA built-in – Authenticator, FIDO2, TAP, SMS
Works with	On-premises resources only	Cloud apps, SaaS, Azure, M365, external apps
Password policy	Group Policy domain-wide	Authentication methods policy per user or group
Multi-tenancy	Single forest typically	Multi-tenant by design – B2B federation built-in

2.2 Why You Cannot Just Replace AD with Entra ID

Entra ID does not support all on-premises AD features. It has no Organisational Units (OUs), no Group Policy Objects (GPOs), no traditional Kerberos authentication for on-premises file servers, no LDAP for legacy applications. Many organisations run BOTH – on-premises AD for legacy workloads and Entra ID for cloud services, connected via Entra Connect.

* This is called a HYBRID model – the most common setup in large enterprises. New cloud-only companies go straight to Entra ID without any on-premises AD.

Section 3 – Identity Models

3.1 Three Identity Models

Model	Description	Authentication	Best For
Cloud-Only	All users exist only in Entra ID. No on-premises AD.	Entra ID handles all authentication directly	New companies, startups, small businesses born in cloud
Hybrid (Synced)	Users in on-premises AD synced to Entra ID via Entra Connect. One source of truth.	Password Hash Sync, Pass-through Auth, or ADFS	Most large enterprises with existing on-premises infrastructure
Federated	On-premises ADFS server handles authentication. Entra ID trusts ADFS tokens.	ADFS handles auth – Entra ID trusts the token	Very large enterprises needing maximum control over authentication

3.2 Authentication Methods in Hybrid

– Password Hash Sync (PHS): Entra Connect syncs a hash of the password hash to Entra ID. Auth happens in cloud. Simplest option. Recommended by Microsoft. Enables Identity Protection risk detection. Works even if on-premises is down.

- Pass-Through Authentication (PTA): Auth request forwarded to on-premises AD via lightweight PTA agents installed on-premises. Password never leaves on-premises. Requires agents always running. On-premises outage means auth failure.
- Active Directory Federation Services (ADFS): Separate ADFS farm handles authentication. Most complex, most expensive, being phased out by most organisations in favour of PHS.
- * For your lab: you set up Hybrid using Password Hash Sync. You updated AD users UPN suffixes to praveenlab2026.onmicrosoft.com in preparation for Entra Connect sync.

Section 4 – Entra ID Object Types

4.1 All Object Types Explained

Object	Description	Key Properties	Created By
User (Member)	Internal person with work or school account. Can sign in and access resources.	UPN, Display Name, Department, Job Title, Usage Location, Licenses, Manager	Admin manually, bulk CSV, PowerShell, or synced from AD
User (Guest)	External person invited to collaborate. Uses their own credentials.	User Type = Guest, External Email, Redemption Status	Admin sends invitation or self-registers
Service Principal	Identity of an application running in your tenant. Created when an enterprise app is added.	App ID, Object ID, Service Principal Type, Permissions	Auto-created when app registered or consented
Managed Identity	Azure resource identity – no password needed, Azure manages credential.	System-assigned (tied to resource) or User-assigned (independent)	Enabled on Azure resources like VMs or Functions
Group	Collection of users, service principals or groups for access control or collaboration.	Group Type, Membership Type, Owners, Members	Admin creates or dynamic rules auto-populate
Application	App registration – defines what an app can do and what permissions it needs.	Client ID, Redirect URIs, API Permissions, Certificates and Secrets	Developer registers via Entra Admin Center
Device	Registered or joined device managed by Entra ID or Intune.	Join Type, Compliance State, OS, Owner, Last Activity, BitLocker Key	Device joins or registers via Windows settings or Intune

Section 5 – User Management and Lifecycle

5.1 User Properties – Most Important Fields

- User Principal Name (UPN): the login email address. Must be unique in tenant. Cannot reuse even after deletion.
- Usage Location: country where user is located. MUST be set before assigning any license. Legal compliance requirement.
- Department: used in Dynamic Group rules – must be exact match. Critical for automation.
- Account Enabled: true means user can sign in. False means blocked. Fastest way to lock out a user.
- User Type: Member (internal) or Guest (external). Affects permissions and features available.

5.2 Joiner Mover Leaver (JML) Lifecycle

Phase	Trigger	Key Actions
JOINER	New employee starts	Create account, set Usage Location, assign license, add to groups, assign manager, configure MFA, set up device via Autopilot, send credentials securely
MOVER	Employee changes role or department	Update Department, Job Title, Manager. Remove from old groups. Add to new groups. Update license if different tier needed.
LEAVER	Employee resigns or is dismissed	1) BLOCK SIGN-IN IMMEDIATELY. 2) Revoke active sessions. 3) Remove licenses. 4) Set Out of Office and forward email to manager. 5) Back up OneDrive and mailbox. 6) Remove from all groups. 7) Delete after retention period.

! For Leavers: Block sign-in is ALWAYS the first action. Not removing license. Not deleting. Block sign-in FIRST. This prevents the departing person from accessing any company data while you perform the rest of the offboarding process.

5.3 Deleted Users

- Deleted users go to Deleted users page and are retained for 30 days
- During 30 days: can be restored with all properties intact
- License must be reassigned after restoration
- After 30 days: permanently deleted, UPN is released, Object ID is released
- OneDrive data is kept for 30 days after account deletion (configurable to 180 days)

5.4 Revoking Sessions

Blocking sign-in prevents future sign-ins but existing tokens (up to 1 hour validity) remain active. To immediately kick someone out of all services: block sign-in AND revoke sessions. Go to user profile -> Revoke sessions. All current access tokens and refresh tokens are immediately invalidated.

Section 6 – Group Types and Management

6.1 Group Types Compared

Group Type	Email Address	SharePoint Site	Teams Channel	Access Control	License Required
Microsoft 365 Group	Yes - shared mailbox	Yes - auto-created	Optional	Yes	No
Security Group	No	No	No	Yes - primary purpose	No
Mail-enabled Security	Yes	No	No	Yes	No
Distribution List	Yes (one-way)	No	No	No	No
Dynamic Security	No	No	No	Yes	Entra ID P1
Dynamic M365	Yes	Yes	Optional	Yes	Entra ID P1

6.2 Dynamic Group Rules

Dynamic groups automatically add and remove members based on user or device attribute rules. They require Entra ID P1 and are evaluated continuously - when an attribute changes, membership updates within minutes.

- (user.department -eq "IT") - all users with Department set to IT
- (user.department -eq "IT") -and (user.userType -eq "Member") - IT members only, no guests
- (user.jobTitle -contains "Engineer") - all users with Engineer in job title
- (user.country -eq "Italy") - all users located in Italy

* Dynamic Groups + Group-Based Licensing = full automation. Create Dynamic Group for IT department, assign Business Premium license to the group. Every new IT hire automatically gets the license the moment their account is created with department=IT.

6.3 Group Governance Features

- Group Expiration: M365 Groups auto-deleted after configured period (e.g. 365 days) if not renewed by owner. Prevents group sprawl. Owners receive email 30, 15, and 1 day before expiry.
- Group Owners: non-admin users who can manage group membership. Reduces IT workload. Team leads manage their own team memberships.
- Group-based licensing: assign license to a group, all members get it automatically. Revoked when removed from group.
- Naming Policy: enforce naming conventions on M365 Groups (prefix or suffix like DEPT- or -ITALY). Prevents random names.

Section 7 – Authentication Methods and MFA

7.1 All Authentication Methods

Method	Security Level	Phishing Resistant	How It Works
Microsoft Authenticator – Push	Very High	No (number matching helps)	Notification on phone – tap Approve. Number matching shows 2-digit code user must enter on phone – prevents fatigue attacks.
Microsoft Authenticator – TOTP	High	No	6-digit code refreshes every 30 seconds. Works offline.
FIDO2 Security Key (YubiKey)	Highest	Yes	Physical key uses cryptography tied to specific website domain. Cannot be intercepted or replayed on fake site.
Windows Hello for Business	High	Yes	Biometric (face/fingerprint) or PIN on Windows device. Certificate-based. Passwordless.
Temporary Access Pass (TAP)	One-time	N/A	Time-limited passcode generated by admin. Used for onboarding or MFA device loss recovery.
Certificate-based Auth (CBA)	High	Yes	X.509 certificate on smart card or device. Enterprise grade.
SMS One-time Passcode	Medium	No	6-digit code sent to phone. Vulnerable to SIM swapping. Avoid where possible.
Voice Call	Medium	No	Automated call, press # to confirm. Accessibility use case.

7.2 Number Matching – Critical Setting

Number matching shows a 2-digit number on the sign-in screen. The user must enter that same number on their Authenticator app to approve. This prevents MFA fatigue attacks where an attacker spams push notifications hoping the user taps Approve by mistake. Without number matching, a stolen password + spammed MFA pushes can lead to account compromise. With number matching, the user must actively type the number – accidental approval is impossible.

7.3 Security Defaults vs Conditional Access

Feature	Security Defaults	Conditional Access
What it is	Simple on/off switch – baseline MFA for everyone	Granular if-then policies with many conditions and controls
Requires P1 license	No – free	Yes – requires Entra ID P1 or P2
Flexibility	None – same rules for all users	Full control – different rules per user, group, app, location, device, risk
Can coexist	Cannot run alongside Conditional Access	Cannot run alongside Security Defaults
Best for	Organisations with free Entra ID only	Any organisation with P1 or P2

! You cannot use Security Defaults and Conditional Access at the same time. You must disable Security Defaults before creating CA policies. Always create an Emergency Admin account FIRST and exclude it from all CA policies before disabling Security Defaults.

Section 8 – Self-Service Password Reset (SSPR)

8.1 What SSPR Does

SSPR allows users to reset their own forgotten passwords without calling IT. Users go to aka.ms/sspr, verify their identity using registered methods, and set a new password immediately. No IT involvement needed. Password resets account for 20-50% of all helpdesk tickets – SSPR eliminates most of these.

8.2 SSPR Configuration Options

- Enabled for: None / Selected groups / All users
- Number of methods required: 1 (less secure) or 2 (recommended)
- Methods available: Microsoft Authenticator, Mobile phone SMS, Email, Security questions

- Registration: require on sign-in, re-confirm every N days (180 recommended)
- Notifications: notify user on reset, notify all admins when admin resets password

8.3 Password Writeback (Hybrid Environments)

In hybrid environments, when a user resets their cloud password via SSPR, Password Writeback automatically writes the new password back to on-premises Active Directory via Entra Connect. Without writeback: cloud password changes but on-premises AD password stays old. User cannot access on-premises resources. With writeback: one reset updates both cloud and on-premises simultaneously.

- Requires: Entra Connect installed with Password Writeback feature enabled
- Also requires: Entra Connect service account has reset password permissions in on-premises AD

Section 9 – Conditional Access – Complete Theory

9.1 What is Conditional Access?

Conditional Access is the intelligent access control gatekeeper of Entra ID. Instead of just checking a password, it evaluates multiple signals before deciding whether to allow, block, or require additional verification. The model is simple: IF (conditions are met) THEN (apply controls).

9.2 Signals (IF Conditions)

Signal	What You Can Check	Example
User or Group	All users, specific users, security groups, or directory roles	Apply policy only to Finance department
Cloud App	All apps, specific M365 services, or specific SaaS apps	Only require MFA for Exchange Online
Location (Named Location)	User IP address, trusted IP ranges, or countries	Block access from outside Italy
Device Platform	Windows, iOS, Android, macOS, Linux	Stricter rules for iOS and Android
Device State	Is device enrolled in Intune? Is it compliant?	Only compliant devices can access email
Client Apps	Browser, mobile apps, desktop clients, legacy auth clients	Block legacy auth (IMAP, POP3, SMTP Auth)
Sign-in Risk (P2)	Entra ID risk detection – unusual sign-in behaviour	Require MFA if risk is Medium or High
User Risk (P2)	Account shows signs of compromise	Block if user risk is High, force password reset

9.3 Grant Controls (THEN Actions)

- Block access: sign-in completely denied. User sees error message.
- Grant – Require MFA: user must complete multi-factor authentication
- Grant – Require compliant device: device must be Intune-enrolled and pass compliance policy
- Grant – Require Entra hybrid join: device must be AD domain-joined AND registered in Entra ID
- Grant – Require approved app: must use Microsoft-approved apps only
- Grant – Require app protection policy: Intune MAM policy must be applied to the app

9.4 Session Controls

- Sign-in frequency: force re-authentication after N hours (e.g. 1 hour for admins)
- Persistent browser session: prevent browser from remembering sign-in
- App enforced restrictions: Exchange Online and SharePoint enforce their own session controls
- Continuous Access Evaluation (CAE): revoke access token immediately when conditions change

9.5 Report-Only Mode

Report-only mode evaluates a policy against real sign-ins without actually enforcing it. The sign-in log shows what WOULD have happened if the policy was On. This is the safest way to test new policies – see the impact before enforcing. Always test in report-only first, check the sign-in logs, confirm no unexpected users would be blocked, then switch to On.

9.6 Common CA Policies Every Organisation Should Have

- CA001 – Require MFA for all users: most important baseline policy
- CA002 – Block access from outside your country: geo-restriction
- CA003 – Require MFA for all admin roles: extra protection for privileged accounts
- CA004 – Block legacy authentication: block IMAP, POP3, SMTP Auth which cannot support MFA
- CA005 – Require compliant device for email: only Intune-managed devices access Exchange
- CA006 – Admin sign-in frequency: force admins to re-authenticate every 1-4 hours

! ALWAYS create an Emergency Admin account and EXCLUDE it from ALL Conditional Access policies. If you lock all admins including yourself, you can be permanently locked out of the tenant with no recovery option.

Section 10 – Privileged Identity Management (PIM)

10.1 The Standing Access Problem

In most organisations, admins have permanent (standing) privileged role assignments. A Global Administrator has GA rights 24/7 even when sleeping or on holiday. If that account is compromised, the attacker has immediate and unlimited access. PIM solves this with Just-In-Time (JIT) access – admins only have rights when they actively need them, for a limited time, and after verification.

10.2 PIM Key Concepts

Concept	Definition	Example
Eligible role	User is allowed to activate this role but does NOT have it permanently active	Admin is Eligible for Global Admin but is NOT a permanent GA
Active role	Role is currently active – user has those permissions right now	Admin activated Exchange Admin for 2 hours
Activation	Process of making eligible role active. Requires justification, MFA, possibly approval.	Admin clicks Activate, enters justification, approves MFA
Activation duration	How long active role lasts before auto-expiring	Global Admin set to 4 hours maximum
Approval workflow	High-risk roles require another person to approve before access granted	GA activation requires approval from a designated approver
Time-bound assignment	Eligible or active assignment expires after a set date	Consultant gets eligible access for 3 months then auto-removed

10.3 PIM Activation Workflow

- Step 1: Admin goes to PIM -> My roles, clicks Activate on eligible role
- Step 2: Selects duration (e.g. 2 hours), enters business justification and ticket number
- Step 3: Completes MFA verification
- Step 4: If approval required – designated approver receives notification and must approve
- Step 5: Role activates for specified duration with full audit trail recorded
- Step 6: At end of duration role auto-expires. Admin can also deactivate manually when done.

* PIM audit log records everything: who activated, which role, when, business justification, how long they had access, who approved. This directly supports ISO 27001 control A.9.2.3 (management of privileged access rights) and SOC 2 CC6.3 (logical access controls).

10.4 PIM Role Settings – Key Options Per Role

- Maximum activation duration: Global Admin = 4 hours. Exchange Admin = 8 hours. Helpdesk Admin = 8 hours.
- Require Azure MFA on activation: always Yes for privileged roles
- Require justification on activation: always Yes – creates audit trail
- Require approval to activate: Yes for Global Admin, Security Admin. No for lower-risk roles.
- Allow permanent eligible assignment: No for most roles (force time-limited eligible assignments)
- Expire eligible assignments after: 6-12 months (force regular review of who is eligible)

Section 11 – Identity Protection and Risk Policies

11.1 What is Identity Protection?

Microsoft Entra Identity Protection uses machine learning and Microsoft's threat intelligence from over 30 trillion daily security signals to detect suspicious sign-in behaviour and compromised accounts. It assigns risk scores automatically and can trigger protective actions in real time.

11.2 Two Types of Risk

Risk Type	What It Represents	Scope	How Used
Sign-in risk	Probability that a specific sign-in attempt is NOT from the legitimate user	Specific sign-in event	Real-time: can block or require MFA during that exact sign-in
User risk	Probability that a user account is compromised based on accumulated evidence	The user account itself	Persistent: stays until remediated. Can block all sign-ins from that account.

11.3 Risk Detections (Common Examples)

- Anonymous IP address: sign-in from Tor browser, known VPN, or anonymous proxy. Real-time.
- Atypical travel: sign-in from Italy then USA 20 minutes later – physically impossible. Offline.
- Leaked credentials: username and password found in dark web breach database. Offline.
- Password spray: many failed attempts across many accounts from same IP. Offline.
- Unfamiliar sign-in properties: device, browser, location user has never used before. Real-time.
- Suspicious inbox manipulation rules: inbox rules forwarding email externally – common in BEC attacks. P2 required.

11.4 Risk Levels and Actions

Risk Level	Confidence	False Positive Rate	Recommended Action
None	No suspicious signals	N/A	No action required
Low	Some suspicious signals, may be legitimate	High	Monitor. May not require immediate action.
Medium	Abnormal behaviour with moderate confidence	Medium	Require MFA. Investigate the user.
High	Strong evidence of compromise	Low	Block immediately. Force password reset. Investigate thoroughly.

11.5 Risk-Based Conditional Access Policies (P2)

- Sign-in risk policy: IF sign-in risk is Medium or above THEN require MFA. Blocks attackers who do not have the MFA device.
- User risk policy: IF user risk is High THEN require password change. Forces legitimate user to reset compromised credentials.
- Both configured in Conditional Access using Sign-in risk and User risk conditions (P2 only)

* In your lab: You generated a real Anonymous IP detection by signing in via Tor Browser as Alice Johnson. Alice was flagged as High risk. CA002 (block outside Italy) also blocked the Tor sign-in simultaneously – both security layers working together.

Section 12 – Enterprise Applications and SSO

12.1 What are Enterprise Applications?

Enterprise Applications represent third-party or Microsoft applications integrated with your Entra ID tenant. When you add an app from the gallery or register a custom app, a Service Principal is created in your tenant – this is the app's identity in your organisation.

12.2 SSO Modes

SSO Mode	Protocol	How It Works	Best For
SAML	SAML 2.0	Entra ID sends XML assertion to app proving user identity. App trusts Entra as identity provider.	Enterprise apps like Salesforce, ServiceNow – pre-OIDC era apps
OpenID Connect (OIDC)	OIDC/OAuth 2.0	Entra ID issues ID token and access token. Modern and flexible.	Modern SaaS apps, custom apps, Microsoft apps
Password-based	HTML form fill	Entra ID stores and auto-fills credentials. No federation needed.	Legacy apps with no SSO support whatsoever
Linked	N/A	Just a link to another SSO system. No actual Entra SSO.	Apps already configured with a different IdP

12.3 App Permissions and Admin Consent

When an app needs to access your organisation's data, it requests permissions. As admin you grant these on behalf of the whole organisation (admin consent) or require each user to individually consent. Always review what an app is requesting before granting admin consent.

- Delegated permissions: app acts on behalf of signed-in user. Limited to what that user can access.
- Application permissions: app acts as itself without any user. Has access to everything the permission allows – higher risk.

! OAuth phishing / consent phishing: attackers create malicious apps requesting broad permissions like Mail.ReadWrite.All. If admin grants consent, attacker can read all email. Always review app permissions carefully before consenting.

Section 13 – App Registrations and Service Principals

13.1 App Registration vs Service Principal

App Registration	Enterprise Application (Service Principal)
The DEFINITION of the app – what it is, what it needs, what URIs it uses	The INSTANCE of the app in your specific tenant
Created by the developer who builds the app	Auto-created when app is registered or added from gallery
Contains: Client ID, Client Secret/Certificate, API permissions, Redirect URIs	Contains: Assignment policy, SSO config, assigned users and groups
Think of it as the app BLUEPRINT	Think of it as the app INSTALLATION in your tenant

13.2 Client Secrets vs Certificates

- Client Secret: a password string that the app uses to authenticate. Simple but must be rotated regularly. Expires after configured period (6 months, 1 year, 2 years, or custom). Treat it like a password.
- Certificate: a public/private key pair. More secure than secrets. Certificate is uploaded to the app registration. Private key stays on the server running the app.

- Managed Identity: for Azure resources – no secret or certificate needed. Azure manages the credential automatically. Best option when running code in Azure.

! Never store client secrets in code or commit them to GitHub. Use Azure Key Vault or environment variables. A leaked secret gives attackers the same access as your application.

13.3 OAuth 2.0 Client Credentials Flow

Used when an application needs to authenticate itself without a user signed in. The app sends its Client ID and Client Secret to Entra ID, receives an access token, and uses that token to call APIs. This is what your PraveenLab PowerShell App used to connect to Microsoft Graph and list all users without any interactive sign-in.

Section 14 – B2B External Collaboration

14.1 B2B Guest Users

Entra ID B2B (Business-to-Business) allows you to invite external people to collaborate using their own credentials – Microsoft account, Google account, or any email. They are created as Guest users in your tenant and can access only the resources you explicitly share with them.

Aspect	Internal User (Member)	External User (Guest)
Account location	Exists in your Entra ID tenant	Exists in their own tenant or uses social/email identity
License required	Yes – full M365 license	No – free up to 5:1 ratio with your licensed users
Default permissions	Full user permissions in M365	Limited – cannot enumerate directory objects by default
Teams experience	Full Teams member	Guest experience – cannot create teams, limited features

14.2 Invitation States

- Pending acceptance: invitation sent, user has not clicked the link yet
- Redeemed: user accepted invitation and signed in at least once
- Not invited: user was added directly without invitation flow

14.3 External Collaboration Settings

- Guest user access: limited access to directory properties (recommended) or same as members
- Guest invite settings: who can invite guests – anyone / members and specific admins / admins only / nobody
- Collaboration restrictions: allow any domain / deny specific domains / allow only specific domains

Section 15 – Entra Connect – Hybrid Identity

15.1 What Entra Connect Does

Microsoft Entra Connect (formerly Azure AD Connect) synchronises on-premises Active Directory users, groups, and devices to Microsoft Entra ID in the cloud. It creates a hybrid identity environment where users have one identity that works for both on-premises and cloud resources.

15.2 Entra Connect Components

- Sync Engine: the core component that reads objects from AD and writes them to Entra ID
- Password Hash Sync (PHS): hashes the password hash and syncs to Entra ID for cloud authentication
- Password Writeback: writes cloud password resets back to on-premises AD (enables SSPR in hybrid)
- Device writeback: writes Entra-registered devices back to on-premises AD
- Entra Connect Health: monitoring service showing sync status and alerts

15.3 UPN Suffix Requirement

On-premises AD users typically have UPN suffix @yourdomain.lan (non-routable). Before syncing to Entra ID, you must either add a verified custom domain or use the onmicrosoft.com domain as the UPN suffix. Users with @yourdomain.lan UPN cannot be synced directly because Entra ID requires routable UPN suffixes.

* In your lab: You added praveenlab2026.onmicrosoft.com as an alternate UPN suffix in AD Domains and Trusts, then updated all 9 Delhi-HQ users to use the new suffix via PowerShell. This prepared them for Entra Connect sync.

Section 16 – Access Reviews and Governance

16.1 What are Access Reviews?

Access reviews are a governance feature that periodically certifies users still need their current access. Instead of assuming access granted 2 years ago is still appropriate, reviewers are asked to confirm or remove access on a regular schedule. Requires Entra ID P2.

16.2 What Can Be Reviewed

- Group membership: who is in a security group or M365 group
- Application access: who has access to an enterprise application
- Entra ID role assignments: who has admin roles (very important for privileged access)
- Guest user access: which guests still need access to groups and apps
- Azure role assignments: who has access to Azure resources

16.3 Review Process

- Step 1: Admin creates review – defines scope, reviewers, duration, recurrence
- Step 2: Reviewers receive email with link to myaccess.microsoft.com
- Step 3: Reviewers see all members with recommendations (last sign-in date, activity)
- Step 4: Reviewer approves (keep access) or denies (remove access) with justification
- Step 5: If auto-apply enabled: denied users are automatically removed after review period
- Step 6: Full audit trail recorded for compliance evidence

* Review recommendations: system shows "Deny" for users who have not signed in recently (inactive users). Helps reviewers make decisions quickly. George Grey who has not signed in for 60 days gets a Deny recommendation.

16.4 Identity Governance Dashboard

The Identity Governance dashboard in Entra shows: number of guest users, groups and teams, applications, access reviews configured, identities with highly privileged roles. Gives a governance overview of your entire tenant at a glance.

Section 17 – Monitoring – Logs, Workbooks, Diagnostics

17.1 Sign-in Logs

Sign-in logs record every authentication attempt against your Entra ID tenant. They are your primary investigation tool for security incidents and troubleshooting access problems.

Log Type	What It Records
User sign-ins (interactive)	Normal user sign-ins via browser or app where user enters credentials
User sign-ins (non-interactive)	Token refresh, background authentication – no user interaction
Service principal sign-ins	Applications signing in using client credentials or certificates
Managed identity sign-ins	Azure resources signing in using managed identity

- Each sign-in entry shows: date/time, user, application, IP address, location, status, CA policies applied
- Retention: 30 days for P1, 90 days for P2. Export to Log Analytics for longer retention.

17.2 Audit Logs

Audit logs record every admin and configuration change in Entra ID. Critical for security investigations, compliance evidence, and tracking who changed what.

- UserManagement: user created, updated, deleted, blocked, role assigned
- GroupManagement: group created, member added/removed, owner changed
- Policy: Conditional Access policy created, updated, deleted
- ApplicationManagement: app registered, permission granted, secret created
- RoleManagement: admin role assigned or removed (very important to monitor)

17.3 Workbooks

Workbooks are pre-built visual reports combining sign-in and audit data into interactive dashboards. Key workbooks include: Sign-in analysis, Conditional Access gap analyzer (shows sign-ins not covered by any CA policy), MFA usage, Risky sign-ins, Authentication methods activity.

17.4 Diagnostic Settings

Diagnostic settings export Entra ID logs to external destinations for long-term retention. Options: Log Analytics workspace (enables KQL queries and Microsoft Sentinel integration), Storage account (archive), Event Hub (real-time streaming to SIEM). This is the foundation for Microsoft Sentinel integration.

Section 18 – Key Concepts and Definitions

18.1 Identity and Protocol Concepts

- OAuth 2.0: modern authorisation protocol. Grants apps access to resources on behalf of users or as themselves.
- OpenID Connect (OIDC): authentication layer on top of OAuth 2.0. Used for user identity verification.
- SAML 2.0: older federation protocol used for SSO with enterprise apps that predate OIDC.
- JWT (JSON Web Token): token issued by Entra ID after successful authentication. Contains claims about the user.
- Claim: piece of information inside the JWT – e.g. display name, email, groups, roles, tenant ID.
- Scope: what permissions an app is requesting access to (User.Read, Mail.ReadWrite etc.)
- Tenant ID: unique GUID identifying your M365 tenant globally.
- Object ID: unique GUID identifying a specific user, group, or app within your tenant.
- UPN: User Principal Name – the login email address. Always in email format.

18.2 Security Concepts

- Zero Trust: never trust, always verify. Assume breach. Use least privilege. Verify explicitly.
- Least Privilege: assign only the minimum permissions needed. Not GA when User Admin is enough.
- JML: Joiner Mover Leaver – the user lifecycle process in IT.
- MFA Fatigue Attack: attacker spams MFA push notifications hoping user approves. Number matching defeats this.
- SIM Swapping: attacker transfers victim phone number to their SIM. Bypasses SMS MFA. Why SMS should be avoided.
- Legacy Authentication: old protocols (IMAP, POP3, SMTP Auth) that cannot support MFA. Must be blocked.
- Phishing-Resistant MFA: FIDO2 and Windows Hello. Cryptographic – cannot be intercepted or replayed.
- Standing Access: permanent admin rights – security risk. PIM replaces with just-in-time access.

18.3 Complete Acronym Reference

Acronym	Full Name	Context
B2B	Business-to-Business	External guest user collaboration
CA	Conditional Access	Identity security policy framework
CBA	Certificate-Based Authentication	PKI-based phishing-resistant MFA

Acronym	Full Name	Context
FIDO2	Fast Identity Online 2	Hardware MFA standard (YubiKey)
IAM	Identity and Access Management	Managing who has access to what
JIT	Just-In-Time	PIM access model – rights only when needed
JML	Joiner Mover Leaver	User lifecycle process
OIDC	OpenID Connect	Modern authentication protocol
PHS	Password Hash Sync	Entra Connect authentication method
PIM	Privileged Identity Management	Just-in-time privileged access (P2)
PTA	Pass-Through Authentication	Entra Connect auth method – on-premises validation
RBAC	Role-Based Access Control	Permissions based on role not individual
SAML	Security Assertion Markup Language	Federation protocol for enterprise SSO
SSPR	Self-Service Password Reset	Users reset own passwords without IT
TAP	Temporary Access Pass	Emergency one-time MFA passcode
UPN	User Principal Name	User login email address in Entra ID

End of Notes – Microsoft Entra ID General Theory

18 Sections – Architecture, Identity Models, Users, Groups, MFA, CA, PIM, Identity Protection, Apps, B2B, Hybrid, Governance, Monitoring